

웹 공격 문자열을 이미지로 바꿔 탐지하는 2단 구조 연구

지난 미팅 지시 2건(평가지표 데이터셋) 이행 현황과, 최근 논문 대조로 지표 선택을 역검증한 결과

보고일 2026-08-24 · 보고 범위 2026-08-13 ~ 2026-08-24

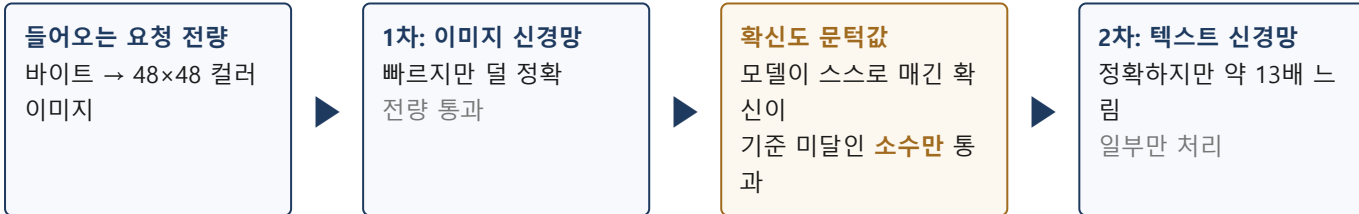
세 줄 요약

- 지시 ① 평가지표 — 말씀하신 대로 기존 요약 지표를 완전히 걷어내고, 보안 분야 최상위 학회의 평가 방법론 논문을 근거로 지표 체계를 다시 세웠습니다. 코드 반영과 시험까지 완료했습니다.
- 다만 "근거 문헌이 있다"와 "실제 최근 논문이 그 지표를 쓴다"는 다른 문제라, 연구 주제가 비슷한 논문들을 역으로 조사했습니다. 그 결과 지표 6종 중 4종은 지지, 1종은 제외, 1종은 조건부로 정리했고 1종을 새로 추가했습니다(4장).
- 지시 ② 데이터셋 — 2010년 데이터를 주 데이터에서 내리고 2020년 실서버 수집 데이터로 교체하기로 확정했습니다. 여기에 2025년 실운영 공격 데이터로 외부 검증을 붙여, "최신성"을 데이터 연도가 아니라 측정된 일반화 성능으로 답하려 합니다(5장).

1. 무엇을 만들고 있는가

문제. 웹 서버로 들어오는 요청에는 SQL 삽입, 크로스사이트 스크립팅, 명령 삽입 같은 공격 문자열이 섞여 들어옵니다. 이것을 실시간으로 걸러내야 하는데, 정확한 모델은 느리고 빠른 모델은 부정확하다는 맞교환이 늘 존재합니다.

접근. 공격 문자열의 바이트 값을 그대로 48×48 컬러 이미지로 바꿔 이미지 분류 신경망에 넣습니다. 문자열을 순서대로 읽는 모델보다 훨씬 빠릅니다. 그런데 정확도는 텍스트 모델이 더 높다는 것이 저희 측정 결과였습니다. 그래서 둘 중 하나를 고르는 대신 둘을 잇는 2단 구조를 제안 모델로 삼았습니다.



문턱값 하나를 조절하면 "전부 빠른 모델" ↔ "전부 정확한 모델" 사이를 연속적으로 오갈 수 있습니다. 1·2차 모두 이미 학습해 둔 모델을 그대로 쓰므로 **추가 학습 비용은 0**입니다.

2. 연구 질문과 지금까지의 답

연구 질문	지금까지의 답	상태
① 공격 문자열을 이미지로 바꾼 탐지는 텍스트 기반 모델과 견주어 정확도-속도 상 어디에 있는가	정확도에서는 진다. 통계 검정으로 확정했습니다. 대신 속도는 크게 앞섭니다	답 완료(음성)
② 그 둘을 잇는 2단 구조 는 얼마나 싸게 같은 정확도를 사는가	전체의 약 8%만 2차로 넘겨 같은 정확도를 유지했습니다. 다만 이 배수에는 조건이 붙습니다(6장)	답 완료
③ 그 구조는 실제 우회 기법 에 얼마나 버티는가	버팁니다. 그런데 정확도가 아니라 속도를 표적으로 하는 공격 이 성립함을 새로 확인했습니다	답 완료
④ 우회 변형을 미리 학습 시키면 못 본 변형까지 막아지는가	대체로 본 것만 외웁니다. 그리고 그 대가를 정확도가 아니라 속도로 지불합니다	답 완료
⑤ 내용이 암호화 되면 내용 기반 탐지는 어디서 무너지는가	탐지를 죽이는 것은 무작위성 자체가 아니라 키에 의한 무작위화 임을 분리해 보였습니다	답 완료
⑥ 1차와 2차의 판단이 엇갈리는 것 자체가 우회 시도의 신호가 되는가	신호는 나오지만 단독 판단 근거로는 약합니다. 보조 지표로만 보고할 예정입니다	부분 답

연구 질문 ①에 대한 서술 원칙. 원래 질문은 "*이미지 기반이 텍스트 모델과 비슷하거나 더 나은가*" 였고 답은 "*아니오*"였습니다. 결과를 본 뒤 질문을 살짝 바꾸면 **사후가설 설정**이 되므로, 논문에는 **원래 질문과 부정적 답을 그대로 싣고**, 2단 구조는 **그 부정적 결과에서 파생된 질문**임을 명시합니다. 이렇게 쓰면 오히려 방법론적 강점이 됩니다.

3. 지시 ① 평가지표 — 무엇을 어떻게 바꿨는가

기존에 쓰던 단일 요약 지표를 **완전히 제거**했습니다. 보고 항목만 지우면 되는 일이 아니라, 그 지표가 코드 안에서 **자동 판단의 기준값**으로 쓰이던 곳이 5군데 있어 함께 옮겼습니다. 현재 자동 시험 168건이 모두 통과합니다. 새 지표 체계의 1차 근거는 보안 분야 최상위 학회 논문으로 교체했습니다.

Arp 외. *Dos and Don'ts of Machine Learning in Computer Security*. USENIX Security 2022. 확장판: *Pitfalls in Machine Learning for Computer Security*. Communications of the ACM 67(11):104–112, 2024. — 보안 분야 기계학습 평가 방법론 비판의 표준 인용 문헌입니다. 원문 두 편을 직접 확보해 대조했습니다.

지표	무엇을 보는가 · 왜 필요한가	상태
클래스 균등 F1	공격 종류별 성능을 같은 비중 으로 평균합니다. 데이터가 적은 공격 종류에서의 실패가 전체 평균에 묻히지 않습니다. 최근 논문들의 공통 보고 단위여서 선행연구와 직접 비교가 됩니다	유지
정밀도-재현율 곡선 넓이	드문 사건을 얼마나 잘 골라내는지를 봅니다	⚠ 조건부(4장)
오탐률 1% 지점의 탐지율	실무 방화벽은 오탐이 적은 구간에서만 쓸 수 있습니다. "평균적으로 잘한다"가 아니라 실제로 운영 가능한 지점에서 얼마나 잡는지를 봅니다	신설
저오탐 구간 곡선 넓이	위와 같은 취지를 곡선 넓이로 요약한 것	❌ 제외 권고(4장)
경보 부하	실제 서비스에서 공격은 전체 요청의 극히 일부입니다. 그 비율을 가정했을 때 100만 요청당 헛경보가 몇 건 인지를 셉니다. 담당자가 감당할 수 있는 양인지를 보는 지표입니다	신설
확신도 교정 오차	모델이 "90% 확신한다"고 할 때 실제로 90% 맞는지를 봅니다. 저희 2단 구조는 확신도로 2차 전달 여부를 결정 하므로 이 값이 구조의 전제입니다	신설

왜 "경보 부하"가 필요한지 보여주는 실례. 정확도 0.997, 클래스 균등 F1 0.995, 곡선 넓이 1.000 인 모델도 — 오탐률이 3%이고 실제 공격이 전체 요청의 0.1%뿐이라면 — **올린 경보 100건 중 진짜는 3건** (100만 요청당 헛경보 29,970건 대 진짜 1,000건)입니다. 기존 지표만 보고했다면 이 모델을 "거의 완벽"으로 보고했을 것입니다.

4. 지표 선택을 최근 논문으로 역검증했습니다

왜 했는가. 처음 근거로 삼은 논문들은 **지표 이름을 검색어로** 찾은 것이었습니다. 그러면 "그 지표를 쓰는 논문을 찾았더니 그 지표를 쓰더라"는 순환 논증이 됩니다. 그래서 이번에는 순서를 뒤집어 **연구 주제가 비슷한 논문을 먼저 찾고, 그들이 실제로 무엇을 보고하는지를** 확인했습니다. 관련 논문 32편을 주제별로 정리했고, 그중 판단의 근거가 되는 7편은 원문 전문을 직접 검색해 대조했습니다.

지표	비슷한 주제의 최근 논문에서의 상태	판정
클래스 균등 F1	사실상 전원이 씁니다. 웹 공격 탐지 논문 하나는 클래스 균등 방식과 가중 방식을 함께 보고합니다 — 저희가 하려던 형식 그 대로입니다	유지
오탐률 1% 지점 탐지율	2단 구조 선행연구가 " 오탐률 1.009%에서 정확도 89.22% "처럼 고정 오탐률 지점으로 보고합니다. 저희와 같은 웹 요청 데이터에서도 그렇게 합니다	유지(근거 확보)
경보 부하	가장 가까운 선행연구가 똑같은 계산 을 이미 하고 있었습니다 — 실제 공격 발생률 3.3%를 놓고 경보량을 추정합니다. 이 계열의 원점 논문(1999)까지 확인했습니다	가장 강한 지지
확신도 교정 오차	웹 공격 탐지 쪽에는 드물지만 침입 탐지 분야 2025~2026년 논문에는 표준으로 들어가 있습니다	유지
정밀도-재현율 곡선 넓이	쓰는 논문이 있으나 이 지표에는 구조적 함정이 있습니다 (아래)	⚠ 조건부
저오탐 구간 곡선 넓이	조사한 논문 전부에서 사용 0건 이었고, 정보가 "오탐률 1% 지점 탐지율"과 상당히 겹칩니다	본문에서 제외

검증에서 나온 시정 사항

(1) **정밀도-재현율 곡선 넓이는 "공격 비율"에 따라 값이 변합니다.** 이 지표는 정밀도를 적분한 값이라, 모델이 전혀 바뀌지 않아도 **시험 데이터에 공격이 몇 %인지에 따라 숫자가 움직입니다.** 그런데 저희 코드는 "경보 부하"만 실제 배포 비율로 환산하고 이 지표는 시험 데이터 비율 그대로 계산하고 있었습니다. 같은 보고서 안에서 두 지표가 서로 다른 전제를 쓰고 있었던 셈입니다. 게다가 저희 시험 데이터는 **공격이 96.8%로 다수**여서, 이 지표가 원래 유용한 "드문 사건" 상황과 정반대입니다. → **보고할 때 그 데이터의 공격 비율을 반드시 함께 적고,** 데이터셋이 다른 것끼리의 비교에는 공격 비율에 영향받지 않는 지표를 쓰기로 했습니다.

(2) **확률 예측 오차 점수(Brier)를 추가합니다.** 확신도 교정을 다루는 최근 논문들이 공통적으로 쓰고 있고, 저희가 쓰던 교정 오차 지표는 값의 구간을 몇 개로 나누느냐에 따라 결과가 달라지는 약점이 있습니다. Brier 점수에는 그런 임의의 선택이 없습니다. 구현은 한 곳만 고치면 됩니다.

(3) **속도 개선 배수에 조건을 명시합니다.** 이것이 이번 검증에서 나온 가장 중요한 발견이라 6장에서 따로 말씀드립니다.

검증 과정에서 저희 판단 하나가 틀렸음을 확인했습니다. 처음에는 "오탐률 고정 지점 보고는 최근 웹 공격 논문이 하지 않는 것이므로 저희만의 차별점"이라고 적었는데, **논문 원문을 열어보니 하고 있었습니다.** 검색 요약만 보고 "선행연구가 하지 않는다"고 적었던 것이 원인입니다. 앞으로 논문 본문에서 선행연구의 부재를 주장할 때는 **원문을 직접 확인한 것만** 쓰기로 하고, 이 원칙을 기록에 남겼습니다.

5. 지시 ② 데이터셋 — 무엇으로 바꾸는가

역할	데이터	내용과 선정 이유
주 데이터	SR-BH 2020 Computers & Security 120 (2022) 102788	2020년 7월, 인터넷에 실제로 노출된 서버에서 12일간 수집한 90.8만 요청. 자동 규칙으로 1차 표시한 뒤 사람이 검수해 교정한 라벨입니다. 2025~2026년 최신 논문들이 실제로 쓰고 있어 직접 비교가 됩니다. 원문 문자열이 그대로 들어 있어 저희 이미지 변환이 수정 없이 동작합니다
외부 검증	2025년 실운영 차단 기록 Data 10(11):186, 2025	2025년 운영 중인 서버가 실제로 차단한 악성 요청 30일분입니다. 정상 요청이 없어 오탐률은 계산할 수 없으므로 탐지율 전용 외부 시험셋으로만 씁니다
비교용	기존 2010년 데이터	삭제하지 않고 선행연구 대조표용 으로만 남깁니다. 최근 논문들이 아직 이 데이터로 성능을 보고하고 있어, 이것이 없으면 숫자를 나란히 놓을 수가 없습니다

왜 2020년 데이터에 2025년 검증을 붙이는가. 2010년을 2020년으로 바꾸는 것만으로는 "그것도 6년 전 아닌가"라는 같은 지적을 다시 받게 됩니다. 대신 **2020년 데이터로 학습한 모델이 2025년 실제 공격을 얼마나 잡는지를** 측정해 보고하면, 최신성 문제를 데이터 연도가 아니라 측정된 일반화 성능으로 답하게 됩니다. 이를 새 연구 질문으로 추가할 계획입니다.

비용을 정직하게 말씀드립니다. 데이터를 교체하면 지금까지의 측정 수치는 전부 다시 내야 합니다 (결과 파일 141개). 코드·구조·방법론은 그대로 살고 **숫자만 재생산**되지만, 학습에 쓰는 그래픽카드가 한 대뿐이라 **순차 실행**해야 합니다. 그래서 데이터와 지표를 먼저 **확정**한 뒤 재측정에 들어가는 순서로 잡았고, 현재 데이터 내려받기 단계입니다.

6. 지금까지의 측정 결과

아래 수치는 모두 지시 이전의 옛 지표·옛 데이터 기준이며, 위 계획에 따라 전면 재측정 대상입니다. 방향성과 구조적 발견은 유지될 것으로 보지만 숫자 자체는 바뀔 수 있습니다.

확인한 사실	근거 수치 (옛 기준)	성격
이미지 단독은 텍스트 모델에 통계적으로 유의하게 열세	5겹 교차검증 + 다중비교 보정 후 $p = 0.0010 \sim 0.0247$	음성 결과
흑백을 컬러 3채널로 바꾼 개선은 진짜	+2.69%p, 보정 후 $p = 0.0037 \sim 0.0201$	확정
2단 구조는 8%만 2차로 넘겨 같은 정확도를 유지	2차 전달 8.0%, 지연 5.07배 감소 ⚠️ 조건 있음 (아래)	제안의 핵심
다만 확신도로 넘길 대상을 고르는 방식은 최적과 거리가 멀다	이상적 선택 대비 14.8배 과다 전달	개선 여지 정량화
속도를 표적으로 하는 공격이 성립	2차 전달률 2.54% → 5.50%(2.17배). 정확도는 그 대로인데 지연만 폭증	새 발견
우회 변형 학습은 본 것만 외운다	학습에 쓴 변형 -4.80%p vs 못 본 변형 -44.20%p	한계 규명
방어의 대가는 정확도가 아니라 속도로 지불된다	정확도 -0.12%p인데 2차 전달률 34.97% → 69.52%	구조 고유 발견
암호화 시점의 붕괴 원인은 키에 의한 무작위화	고정 키 방식은 0.9445 유지 → 표준 암호화에서 0.3965로 붕괴	경계 규명
더 큰 모델(트랜스포머 계열)은 채택하지 않음	차이 +0.12%p, $p = 1.0000$ (차이 없음)	부정 결과
1차 모델 내부의 조기 종료도 채택하지 않음	연산을 18% 줄였는데 실제 시간은 오히려 +3.3%	부정 결과

⚠️ 속도 5.07배에는 조건이 붙습니다 — 이번 검증의 가장 큰 발견입니다.

2단 구조의 실제 속도 이득은 들어오는 요청 중 공격이 몇 %인지에 따라 달라집니다. 1차 모델이 확신하는 것을 걸러내는 구조이기 때문입니다. 그런데 저희가 측정한 데이터는 공격이 96.8%로, 실제 웹 서비스(보통 수 % 이하)와 정반대입니다. 가장 가까운 선행연구도 "현실적인 공격 비율에서 추정해야 한다"고 명시하고 3.3%를 사용합니다.

→ 재측정 시 배포 환경의 공격 비율(1%-0.1%-3.3%)에서 다시 계산해 함께 싣고, 조건 없는 "5.07배"는 쓰지 않기로 했습니다. 지표 선택이 아니라 핵심 주장의 성립 조건에 관한 문제여서 가장 먼저 처리합니다.

7. 논문에 정직하게 함께 적을 한계

- 이미지 단독 방식은 텍스트 모델에 진다 — 숨기지 않고 그대로 씁니다.
- 깨끗한 데이터에서는 두 모델이 서로 보완하지 않습니다(놓치는 것이 거의 동일).
- 공격자가 저희 방어를 알고 맞춰서 적응하는 공격은 아직 수행하지 못했습니다.
- 1차 모델 내부의 조기 종료는 시도했으나 효과가 없어 채택하지 않았습니다 — 그대로 보고합니다.
- 1·2차의 판단 불일치를 우회 탐지 신호로 쓰는 아이디어는 기준에 못 미쳐 보조 지표로만 씁니다.
- 속도 개선 배수는 위와 같이 공격 비율 조건부입니다.

부정적 결과를 남기는 편이 오히려 유리하다고 판단했습니다. 조사한 유사 선행연구 8편 중 통계적 유의성 검정을 한 논문이 0편이어서, 검정과 부정 결과를 함께 싣는 것 자체가 차별점이 됩니다.

8. 남은 일정

순서	할 일	상태
1	새 데이터 내려받기 · 형식과 라이선스 직접 확인	진행 중
2	공격 유형 라벨을 기존 4개 분류로 대응시키는 규칙 구현	대기
3	이미지 변환 절차를 새 데이터에 연결	대기
4	모델 6종 본 측정 + 5겹 교차검증	대기
5	2단 구조 문턱값 재선택 + 속도 배수를 실제 공격 비율에서 재계산	대기(최우선)
6	우회 공격 · 방어 재측정	대기
7	2025년 데이터로 외부 검증(시간축 일반화)	대기
8	2010년 데이터 대조표(선행연구 비교용)	대기

9. 여쭙고 싶은 것

1 저오탐 구간 곡선 넓이를 본문에서 빼도 괜찮겠는지요.

조사한 논문 어디에서도 쓰지 않았고 다른 지표와 정보가 겹칩니다. 다만 지표 수가 줄면 "부실해 보이는" 인상을 줄 수 있어, 본문에서는 빼되 부록에 남기는 선으로 정리할까 합니다.

2 속도 배수를 어느 공격 비율 기준으로 보고할지요.

1%·0.1%를 함께 싣는 것을 기본으로 하되, 선행연구와 직접 비교하려면 그쪽이 쓴 3.3%도 병기하는 편이 낫다고 봅니다. 셋을 다 싣는 것이 번잡하다면 어느 쪽을 대표로 둘지 정해 주시면 좋겠습니다.

3 2025년 외부 검증을 새 연구 질문으로 세워도 되겠는지요.

기존 질문에 딸린 실험으로 둘 수도 있으나, "시간이 지난 데이터로 학습한 탐지기가 최신 공격에 통하는가"는 독립된 질문으로 세우는 편이 지시 ②에 대한 답으로도 분명해 보입니다.